

LAPORAN WORKSHOP DEVOPS

BAB 1 :

FONDASI TEORITIS DAN KERANGKA KERJA DEVSECOPS



Oleh:

Muhammad Bagus Prayogi (3126640057)

Dosen Pengajar:

Dr. Ferry Astika Saputra, ST, M.Sc

**PROGRAM STUDI SARJANA TERAPAN LANJUT JENJANG TEKNIK
INFORMATIKA**

**DEPARTEMEN TEKNIK INFORMATIKA DAN KOMPUTER
POLITEKNIK ELEKTRONIKA NEGERI SURABAYA**

2026

PENDAHULUAN

Transformasi digital menuntut organisasi untuk mengembangkan perangkat lunak yang tidak hanya cepat, tetapi juga aman. Evolusi dari metode pengembangan tradisional (Waterfall) menuju Agile dan DevOps telah terbukti mampu meningkatkan kecepatan *delivery* aplikasi melalui otomatisasi *Continuous Integration/Continuous Deployment* (CI/CD). Namun, kecepatan ini memunculkan celah risiko yang besar apabila pengujian keamanan baru dilakukan pada tahap akhir menjelang rilis.

Oleh karena itu, pendekatan DevSecOps hadir untuk mengintegrasikan kontrol keamanan secara berkelanjutan ke dalam seluruh siklus pengembangan. Praktikum ini dilaksanakan untuk menanamkan fondasi bahwa DevSecOps bukanlah sekadar sekumpulan tools pemindai otomatis, melainkan sebuah sistem sosio-teknis yang mengandalkan kolaborasi, budaya tanggung jawab bersama, dan ketersediaan bukti jaminan (evidence) yang dapat diaudit.

Adapun tujuan dari pelaksanaan praktikum pengantar ini adalah sebagai berikut:

1. Menjelaskan DevSecOps sebagai sebuah sistem sosio-teknis yang terintegrasi, bukan sekadar penambahan alat keamanan pada *pipeline*.
2. Memetakan praktik DevSecOps dengan standar industri yang berlaku, seperti kerangka kerja NIST SSDF, panduan OWASP, dan jaminan SLSA.
3. Membedakan penerapan *shift-left*, *shift-right*, penetapan *security gate*, dan pengumpulan *evidence* yang valid.
4. Menyusun dan memverifikasi *baseline* (titik awal) laboratorium pengujian yang aman, terstandarisasi, dan siap digunakan untuk eksperimen selanjutnya.

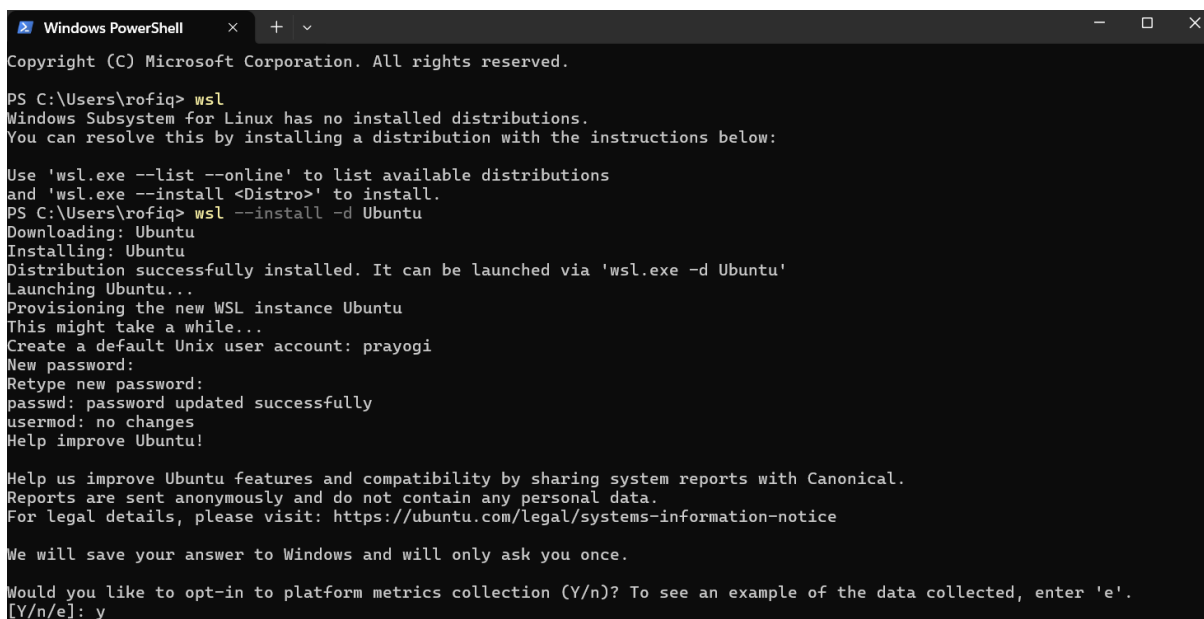
DevSecOps tidak dapat direduksi hanya dengan memasang perangkat lunak pemindai (scanner) ke dalam pipeline CI/CD, karena alat secanggih apapun akan gagal jika tidak diimbangi dengan perubahan budaya kerja organisasi. Sebagai sebuah sistem sosio-teknis, DevSecOps memadukan elemen manusia, proses, dan teknologi di mana tim Pengembang (Developer), Operasi (Operations), dan Keamanan (Security) berbagi tanggung jawab yang sama. Integrasi ini mendistribusikan keputusan keamanan kepada pihak yang memiliki konteks teknis paling sesuai, sehingga kontrol keamanan berfungsi sebagai pagar pengaman (guardrail) yang terotomatisasi, bukan sekadar gerbang inspeksi manual yang memperlambat laju rilis aplikasi.

PRAKTIKUM 1

Arsitektur laboratorium dan prasyarat lingkungan yang dibutuhkan pada praktikum kali ini sekaligus sebagai lingkungan dasar Mata Kuliah Workshop DevOps adalah menggunakan menggunakan satu host Linux atau mesin virtual yang menjalankan Docker Engine dan Docker Compose. Lingkungan diperlakukan sebagai baseline terisolasi: versi sistem, resource, network, izin pengguna, dan status daemon dicatat sebelum eksperimen agar hasil dapat direproduksi.

Dikarenakan perangkat utama menggunakan sistem operasi Windows, maka dilakukan penyesuaian menggunakan fitur WSL (*Windows Subsystem for Linux*).

- **Langkah 1: Masuk ke Lingkungan Linux**



```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Users\rofiq> wsl
Windows Subsystem for Linux has no installed distributions.
You can resolve this by installing a distribution with the instructions below:

Use 'wsl.exe --list --online' to list available distributions
and 'wsl.exe --install <Distro>' to install.
PS C:\Users\rofiq> wsl --install -d Ubuntu
Downloading: Ubuntu
Installing: Ubuntu
Distribution successfully installed. It can be launched via 'wsl.exe -d Ubuntu'
Launching Ubuntu...
Provisioning the new WSL instance Ubuntu
This might take a while...
Create a default Unix user account: prayogi
New password:
Retype new password:
passwd: password updated successfully
usermod: no changes
Help improve Ubuntu!

Help us improve Ubuntu features and compatibility by sharing system reports with Canonical.
Reports are sent anonymously and do not contain any personal data.
For legal details, please visit: https://ubuntu.com/legal/systems-information-notice

We will save your answer to Windows and will only ask you once.

Would you like to opt-in to platform metrics collection (Y/n)? To see an example of the data collected, enter 'e'.
[Y/n/e]: y
```

Gambar 1. Instalasi awal distribusi Linux Ubuntu

Instalasi awal distribusi Linux Ubuntu dijalankan melalui PowerShell menggunakan perintah interaktif `wsl --install -d Ubuntu`. Setelah proses pengunduhan dan instalasi selesai, sistem meminta pembuatan akun pengguna UNIX baru atas nama `prayogi` beserta konfirmasi kata sandi (*password*). Terminal WSL kemudian dibuka kembali, dilanjutkan dengan perintah `cd ~` untuk memastikan akses masuk sudah berada secara tepat di dalam *home directory* sistem Linux.

- **Langkah 2: Pembuatan Direktori Laboratorium**

Pembuatan direktori kerja tunggal dilakukan untuk memusatkan seluruh berkas latihan dan eksperimen. Perintah `mkdir -p ~/devsecops-lab/{app,policy,reports,sbom,keys}` dieksekusi untuk membuat folder utama `devsecops-lab` beserta lima subdirektori pendukung secara sekaligus, yaitu folder `app`, `policy`, `reports`, `sbom`, dan `keys`. Pengguna kemudian masuk ke dalam folder tersebut menggunakan perintah `cd ~/devsecops-lab` dan memverifikasi struktur direktori dengan perintah `ls -`

1 guna memastikan seluruh folder hak akses telah tercipta dengan benar.

```
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Users\rofiq> wsl
prayogi@MSI:/mnt/c/Users/rofiq$ cd ~
prayogi@MSI:~$ mkdir -p ~/devsecops-lab/{app,policy,reports,sbom,keys}
prayogi@MSI:~$ cd ~/devsecops-lab
prayogi@MSI:~/devsecops-lab$ ls -l
total 20
drwxr-xr-x 2 prayogi prayogi 4096 Aug 31 20:33 app
drwxr-xr-x 2 prayogi prayogi 4096 Aug 31 20:33 keys
drwxr-xr-x 2 prayogi prayogi 4096 Aug 31 20:33 policy
drwxr-xr-x 2 prayogi prayogi 4096 Aug 31 20:33 reports
drwxr-xr-x 2 prayogi prayogi 4096 Aug 31 20:33 sbom
```

Gambar 2. Pembuatan Direktori Labolatorium

- **Langkah 3: Pengecekan Versi Komponen (Baseline)**

Sebelum memulai konfigurasi keamanan lebih lanjut, status *daemon* Docker diaktifkan terlebih dahulu menggunakan perintah hak akses administratif `sudo service docker start`. Merekam versi komponen perangkat lunak yang digunakan sangat krusial agar seluruh hasil pengujian dan pemindaian kerentanan di masa mendatang dapat direproduksi secara akurat. Perintah *baseline* yang dieksekusi mencakup pemeriksaan versi Docker Engine (`docker version`), pemeriksaan plugin orkestrasi (`docker compose version`), pelacakan versi pengelola kode (`git --version`), pustaka kriptografi (`openssl version`), hingga utilitas transfer data jaringan (`curl --version`).

```
prayogi@MSI:~$ sudo service docker start
[sudo: authenticate] Password:
 * Starting Docker: docker
 * Docker is running
prayogi@MSI:~$ cd ~/devsecops-lab
prayogi@MSI:~/devsecops-lab$ docker version
Client: Docker Engine - Community
Version: 29.7.2
API version: 1.55
Go version: go1.26.5
Git commit: a7dcaa6
Built: Wed Aug 5 18:28:40 2026
OS/Arch: linux/amd64
Context: default

Server: Docker Engine - Community
Engine:
Version: 29.7.2
API version: 1.55 (minimum version 1.40)
Go version: go1.26.5
Git commit: 6a43e3d
Built: Wed Aug 5 18:28:40 2026
OS/Arch: linux/amd64
Experimental: false
containerd:
Version: v2.3.4
GitCommit: db8809540e1a7a9da5d518876894933ff55692ab
runc:
Version: 1.4.3
GitCommit: v1.4.3-0-gbb14dabe
docker-init:
Version: 0.19.0
GitCommit: de40ad0
```

```

prayogi@MSI:~/devsecops-lab$ docker compose version
Docker Compose version v5.5.0
prayogi@MSI:~/devsecops-lab$ git --version
git version 2.53.0
prayogi@MSI:~/devsecops-lab$ openssl version
OpenSSL 3.5.5 27 Jan 2026 (Library: OpenSSL 3.5.5 27 Jan 2026)
prayogi@MSI:~/devsecops-lab$ curl --version
curl 8.18.0 (x86_64-pc-linux-gnu) libcurl/8.18.0 OpenSSL/3.5.5 zlib/1.3.1 bro
t-krb5/1.22.1 OpenLDAP/2.6.10
Release-Date: 2026-01-07, security patched: 8.18.0-1ubuntu2.4
Protocols: dict file ftp ftps gopher gophers http https imap imaps ipfs ipns
Features: alt-svc AsynchDNS brotli GSS-API HSTS HTTP2 HTTPS-proxy IDN IPv6 Ke
prayogi@MSI:~/devsecops-lab$ docker info --format '{{json .SecurityOptions}}'
[{"name=seccomp,profile=builtin","name=cgroupns"}]
prayogi@MSI:~/devsecops-lab$ |

```

Gambar 3. Pengecekan Versi Komponen (Baseline)

- **Pengecekan Fitur Keamanan Docker**

Memeriksa status mekanisme pengamanan lapis bawah (*security options*) yang aktif pada *daemon* Docker. Pengecekan ini dilakukan dengan mengeksekusi parameter pemformatan khusus melalui perintah `docker info --format '{{json .SecurityOptions}}'` untuk menampilkan modul pengamanan *host* seperti profil *seccomp* dan *cgroupns*.

```

prayogi@MSI:~/devsecops-lab$ docker info --format '{{json .SecurityOptions}}'
[{"name=seccomp,profile=builtin","name=cgroupns"}]
prayogi@MSI:~/devsecops-lab$ |

```

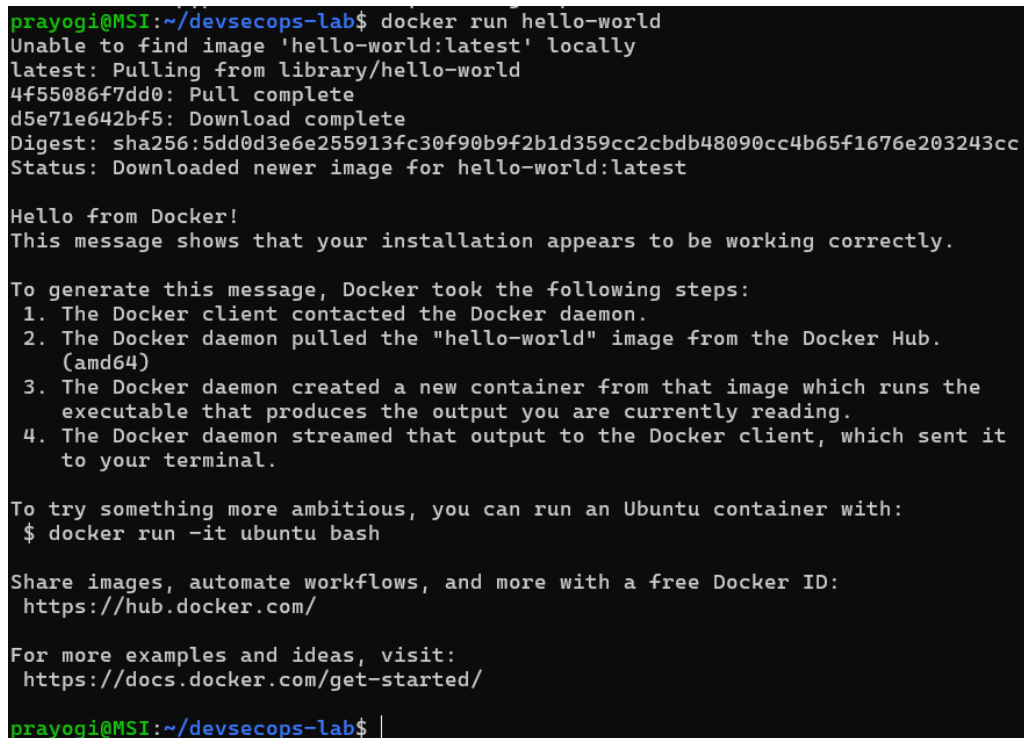
Gambar 4. Pengecekan Fitur Keamanan Docker

ANALISIS

Hasil dari praktikum 1 berhasil membangun sebuah lingkungan laboratorium yang terisolasi dan sesuai dengan kebutuhan Mata Kuliah Workshop DevOps. Sistem operasi Linux berbasis Ubuntu berhasil berjalan optimal di atas Windows melalui WSL.

Sebagai tahapan verifikasi terakhir dari rangkaian *baseline*, dilakukan pengujian fungsionalitas *daemon* Docker:

- **Langkah 5: Pengujian Akhir (*Hello World*)**

A screenshot of a terminal window with a dark background. The prompt is 'prayogi@MSI:~/devsecops-lab\$'. The command 'docker run hello-world' has been executed. The output shows that Docker pulled the 'hello-world:latest' image from the Docker Hub, downloaded it, and ran it. The container outputs 'Hello from Docker!' followed by a message stating that the installation appears to be working correctly. It then lists the steps Docker took to generate this message: 1. The Docker client contacted the Docker daemon. 2. The Docker daemon pulled the 'hello-world' image from the Docker Hub. (amd64) 3. The Docker daemon created a new container from that image which runs the executable that produces the output you are currently reading. 4. The Docker daemon streamed that output to the Docker client, which sent it to your terminal. Below this, it suggests trying something more ambitious by running an Ubuntu container with '\$ docker run -it ubuntu bash'. It also provides links to share images and more Docker resources, and a link for more examples and ideas. The prompt returns to 'prayogi@MSI:~/devsecops-lab\$' with a cursor at the end.

```
prayogi@MSI:~/devsecops-lab$ docker run hello-world
Unable to find image 'hello-world:latest' locally
latest: Pulling from library/hello-world
4f55086f7dd0: Pull complete
d5e71e642bf5: Download complete
Digest: sha256:5dd0d3e6e255913fc30f90b9f2b1d359cc2cbdb48090cc4b65f1676e203243cc
Status: Downloaded newer image for hello-world:latest

Hello from Docker!
This message shows that your installation appears to be working correctly.

To generate this message, Docker took the following steps:
 1. The Docker client contacted the Docker daemon.
 2. The Docker daemon pulled the "hello-world" image from the Docker Hub.
    (amd64)
 3. The Docker daemon created a new container from that image which runs the
    executable that produces the output you are currently reading.
 4. The Docker daemon streamed that output to the Docker client, which sent it
    to your terminal.

To try something more ambitious, you can run an Ubuntu container with:
$ docker run -it ubuntu bash

Share images, automate workflows, and more with a free Docker ID:
https://hub.docker.com/

For more examples and ideas, visit:
https://docs.docker.com/get-started/

prayogi@MSI:~/devsecops-lab$ |
```

Gambar 5. Run Docker Hello World

Pengujian fungsionalitas dijalankan melalui perintah `docker run hello-world`. Perintah ini memicu klien Docker untuk menghubungi *daemon*, mengunduh *image* uji coba `hello-world` secara otomatis dari registri Docker Hub karena belum tersedia secara lokal, serta mengeksekusi kontainer tersebut hingga menghasilkan keluaran teks verifikasi sukses. Proses ini membuktikan secara empiris bahwa komunikasi antara klien dan *daemon* Docker di dalam ekosistem WSL telah berjalan dengan sempurna tanpa kendala.

EVALUASI & LATIHAN MANDIRI

1. Mengapa DevSecOps tidak dapat direduksi menjadi penambahan scanner pada pipeline?

DevSecOps merupakan sebuah sistem sosio-teknis yang mengintegrasikan elemen manusia, proses, dan teknologi. Menambahkan *scanner* pada *pipeline* tanpa adanya kolaborasi atau peran proaktif antar tim akan membuat alat tersebut menjadi sia-sia. DevSecOps harus dijalankan sebagai tanggung jawab bersama oleh seluruh lini (pengembang, operasional, dan keamanan).

2. Evidence apa yang membedakan klaim kontrol dari kontrol yang benar-benar terverifikasi?

- **Klaim kontrol:** Pernyataan bahwa sistem telah aman.
- **Kontrol yang terverifikasi:** Klaim yang disertai dengan bukti nyata (*evidence*) yang dapat diaudit secara independen. Bukti ini berupa laporan pemindaian (SARIF), *Software Bill of Materials* (SBOM), catatan evaluasi kebijakan, log *deployment*, hingga tanda tangan digital (*digital signature*) yang dapat dilacak kembali ke asal perubahan.

3. Bagaimana shared responsibility memengaruhi ownership risiko dan tindak lanjut temuan?

Prinsip tanggung jawab bersama (*shared responsibility*) mendistribusikan keputusan keamanan dan penanganan masalah kepada pihak yang memiliki konteks teknis paling sesuai tanpa duplikasi tugas. Tim keamanan merancang standar dan aturan, pengembang bertanggung jawab mematuhi dan memperbaiki celah kode secara langsung, sementara tim operasi menjaga keamanan infrastruktur.